

소프트웨어 개발보안 점검 결과 보고서

OHS (안전보건 사진분석 서비스) · serving-team/08-app

1. 점검 개요

점검 기준	행정안전부/KISA 「소프트웨어 개발보안 가이드」 49개 보안약점 (7대 유형)
점검 대상	serving-team/08-app — FastAPI backend + React/Vite frontend
기준 산출물	최신 빌드 이미지 ohs-backend:airgap (sha256:d39e3fe9207a..., 2026-06-22 19:49 빌드)
소스 일치	이미지 /app/app == 로컬 backend/app (diff 0) → 정적분석 결과가 곧 배포 이미지 기준
점검 일자	2026-06-23
점검 방법	자동 스캔(SAST·SCA·Secrets) + 49항목 수동 매핑/코드리뷰

2. 종합 결론

중대(High/Critical) 보안약점은 발견되지 않았습니다. 49개 점검항목 중 양호 25건, 조치완료 6건, 해당없음 18건이며, 5종 자동 스캔(bandit·semgrep·OSV/pip-audit·npm audit·gitleaks) 어디에서도 High/Critical 등급 실취약점은 검출되지 않았습니다. 기존 권고 2건(분석 엔드포인트 레이트리미트 강화 · 소스 DB 자격증명 제거)은 코드로 조치 완료했으며, 의존성 1건(chromadb)은 사용하지 않는 서버모드 취약점으로 실익이 없습니다.

3. 자동 스캔 결과 요약

점검 도구	유형	대상	결과
Bandit 1.9.4	SAST (Python)	backend 13,362 LOC	High 0 · Med 2 · Low 5
Semgrep (273 rules)	SAST (다언어/OWASP)	167 files	ERROR 0 · WARNING 0 · INFO 3
OSV.dev / pip-audit	SCA (Python 의존성)	이미지 102 packages	1 (chromadb·비활성경로)
npm audit	SCA (frontend 의존성)	package-lock	2 (dev-time·운영 미포함)
gitleaks	Secrets (시크릿)	270 commits / 614 MB	0 (유출 없음)

※ 스캔 원본(JSON): security/reports/ (bandit.json·semgrep.json·osv-image.json·npm-audit.json·gitleaks.json·image-pip-freeze.txt)

4. 발견사항 검토 (triage)

항목	심각도	상태	판단 / 조치
chromadb CVE-2026-45829 (의존성)	서버모드 High	비해당	PersistentClient 임베디드 사용(서버 미노출) → 공격경로 없음. fix 미출시 → 버전 모니터링.
vite / esbuild (frontend)	High / Mod	운영 미포함	devDependency 빌드툴. 운영 이미지(nginx+static)에 미탑재 → 운영 영향 없음. (차기 vite 메이저 업글)
기본 DB 비밀번호 (config.py)	Med	조치완료	소스 기본값 제거 → .env 주입 필수화(미설정 시 기동 차단). 템플릿/문서 placeholder. semgrep WARN 해소.
분석 엔드포인트 남용	운영시 Med	조치완료	/image 10/분 · /text 20/분 엔드포인트별 레이트리미트 추가(+전역). 429 차단 검증. admin/결제 기능 없음.
bandit Med 2·Low 5	Low	양호(판단)	0.0.0.0 바인딩=컨테이너 표준 / urlopen=내부 Fuseki 고정 / try-except=의도된 폴백.

5. 49개 보안약점 점검 결과 (7대 유형)

No	구분	보안약점	결과	근거 / 대응
1	입력데이터 검증 및 표현	SQL 삽입 (SQL Injection)	양호	SQLAlchemy text()/execute() 전 구간 파라미터 바인딩. 동적 f-string SQL 0건(grep-bandit-semgrep 교차확인).
2	입력데이터 검증 및 표현	경로 조작 및 자원 삽입	양호	업로드는 메모리 스트림 처리, 사용자입력 파일경로 직접참조 없음. bandit B310(urlopen)은 고정 내부 Fuseki 엔드포인트로 오탐.
3	입력데이터 검증 및 표현	크로스사이트 스크립트 (XSS)	양호	React JSX 자동 이스케이프. dangerouslySetInnerHTML/innerHTML/eval 0건. semgrep react 를 무검출.
4	입력데이터 검증 및 표현	운영체제 명령어 삽입	양호	os.system-subprocess(shell=True)-eval-exec 0건(bandit B602/B605/B307 미검출).
5	입력데이터 검증 및 표현	위험한 형식 파일 업로드	조치완료	확장자 화이트리스트(.jpg/.jpeg/.png/.webp) + Pillow 매직검증 + filename 없으면 거부 + 크기 선검증(file_handler.py).
6	입력데이터 검증 및 표현	신뢰되지 않는 URL 주소로 자동 연결	양호	사용자입력 기반 리다이렉트 없음. 외부요청은 고정 config 엔드포인트(Fuseki/OpenAI)에 한정.
7	입력데이터 검증 및 표현	XQuery 삽입	해당없음	XML 데이터베이스/XQuery 미사용.
8	입력데이터 검증 및 표현	XPath 삽입	해당없음	XPath 미사용.
9	입력데이터 검증 및 표현	LDAP 삽입	해당없음	LDAP/디렉터리 서비스 미사용.
10	입력데이터 검증 및 표현	크로스사이트 요청 위조 (CSRF)	양호	세션쿠키 기반 상태변경 없음(stateless API) → CSRF 표면 최소. 남용은 레이트리미트로 방지.
11	입력데이터 검증 및 표현	HTTP 응답 분할	양호	응답헤더에 사용자입력 직접삽입 없음. Starlette가 헤더 개행(CRLF) 차단.
12	입력데이터 검증 및 표현	정수 오버플로우	해당없음	Python 임의정밀 정수 — 정수 오버플로우 비해당.
13	입력데이터 검증 및 표현	보안기능 결정에 안전하지 않은 입력값 사용	양호	쿠키/세션 값을 신뢰한 보안결정 로직 없음.
14	입력데이터 검증 및 표현	메모리 버퍼 오버플로우	해당없음	메모리 안전 런타임(Python) — 네이티브 버퍼 직접조작 없음.
15	입력데이터 검증 및 표현	포맷 스트링 삽입	해당없음	C printf 계열 없음. 사용자입력을 포맷지정자로 사용하지 않음(bandit 확인).
16	보안 기능	적절한 인증 없는 중요기능 수행	조치완료	admin/결제 등 인증 필요 기능 없음(단일 공개 조회). 비싼 분석 엔드포인트에 엔드포인트별 레이트리미트 추가(/image 10/분./text 20/분) + 전역(120/분·1000/일). 429 차단 검증 완료.
17	보안 기능	부적절한 인가	양호	역할/권한 분기 없는 단일 공개 조회 서비스. 접근제어는 서버측 처리.
18	보안 기능	중요한 자원에 대한 잘못된 권한 설정	양호	컨테이너 격리 실행. HOST=0.0.0.0은 컨테이너 표준(nginx 리버스프록시 뒤). bandit B104는 의도된 바인딩.
19	보안 기능	하드코딩된 비밀번호	조치완료	소스 기본 DB 자격증명 제거(config.py) → .env/환경변수 주입 필수화(미설정 시 기동 차단, database.py). 추적 템플릿/문서 placeholder화. gitleaks 유출 0, semgrep WARN 해소.
20	보안 기능	하드코딩된 암호화 키	양호	소스 내 암호화 키 없음. OPENAI_API_KEY 등 전부 env 기반. gitleaks 0건.
21	보안 기능	충분하지 않은 키 길이 사용	해당없음	앱 자체 암호키 생성 없음. TLS 키는 nginx/Let's Encrypt(2048bit+).
22	보안 기능	취약한 암호화 알고리즘 사용	양호	MD5는 캐시키 전용(usedforsecurity=False) — 보안용도 아님. 취약 보안해시 미사용.
23	보안 기능	암호화되지 않은 중요 정보 저장	양호	개인정보/비밀번호 영속 저장 없음(사진 미영속, DB는 공개 온톨로지 데이터).
24	보안 기능	암호화되지 않은 중요 정보 전송	조치완료	운영 전송구간 HTTPS/TLS 적용(nginx).
25	보안 기능	취약한 비밀번호 허용	해당없음	사용자 계정/비밀번호 정책 없음(인증 미도입).
26	보안 기능	사용자 하드디스크에 암호화되지 않은 중요 정보 저장	양호	브라우저 localStorage에 민감정보 저장 없음(비민감 분석결과만).
27	보안 기능	주석문 안에 포함된 비밀번호 등 중요 정보	양호	주석 내 자격증명/시스템정보 노출 없음(gitleaks 270커밋 0 + 수동검토).

No	구분	보안약점	결과	근거 / 대응
28	보안 기능	솔트(Salt) 없는 일방향 암호화	해당없음	비밀번호 해시 저장 없음.
29	보안 기능	무결성 검사 없는 코드 다운로드	해당없음	런타임 동적 코드 다운로드 없음. 의존성은 빌드시 고정(airgap 이미지).
30	보안 기능	보안 기능을 우회할 수 있는 취약한 인증	해당없음	인증 메커니즘 미도입(공개). 도입 시 MFA-무작위대입 차단 권고.
31	보안 기능	부적절한 전자서명 검증	해당없음	전자서명 검증 기능 없음.
32	시간 및 상태	경쟁 조건: 검사시점과 사용시점 (TOCTOU)	양호	파일 처리 메모리 스트림 기반 — 검사-사용 경로 재참조 없음(TOCTOU 표면 없음).
33	시간 및 상태	종료되지 않는 반복문 또는 재귀함수	양호	외부호출 타임아웃 설정(Fuseki 5s-urlopen timeout). 무한루프/무한재귀 없음.
34	시간 및 상태	제어문을 사용하지 않는 대입	양호	공유 가변상태는 읽기중심 캐시-lazy 싱글톤. 동기화 결손 없음.
35	에러 처리	오류 메시지를 통한 정보 노출	조치완료	전역 예외핸들러로 일반화 메시지 응답, 상세(str(e))는 서버로그 한정(main.py)(F7).
36	에러 처리	오류 상황 대응 부재	양호	예외 로깅 기본. bandit B110/B112 5건은 비핵심 graceful degradation(EXIF 회전 등)-noqa 명시.
37	에러 처리	부적절한 예외 처리	양호	광범위 except는 비핵심 폴백 한정, 핵심경로는 구체 예외로 분기.
38	코드 오류	널 포인터 역참조 (Null Pointer Dereference)	양호	Optional 타입힌트 + None 체크. Python은 메모리 손상 없이 AttributeError로 안전실패.
39	코드 오류	부적절한 자원 해제	양호	DB세션 context manager(get_db)-파일/urlopen with-block로 확정 해제.
40	코드 오류	해제된 자원 재사용	해당없음	GC 관리 런타임 — 수동 해제/use-after-free 비해당.
41	코드 오류	초기화되지 않은 변수 사용	해당없음	Python 미할당 변수는 NameError(정의된 동작). bandit 0건.
42	캡슐화	제거되지 않은 디버그 코드	양호	DEBUG 기본 False. 백도어/테스트 코드-디버그 print 없음(logging 사용).
43	캡슐화	시스템 데이터 정보 노출	조치완료	예외 일반화 + 보안헤더(X-Content-Type-Options-X-Frame-Options-Referrer-Policy) 미들웨어(F7).
44	캡슐화	Public 메소드로부터 반환된 Private 배열	해당없음	Java 관용 패턴 — Python 캡슐화 모델 상이.
45	캡슐화	Private 배열에 Public 데이터 할당	해당없음	Java 관용 패턴 — 해당 없음.
46	캡슐화	부적절한 상속 구조	양호	보안민감 클래스 상속-오버라이드 패턴 없음.
47	API 오용	취약한 API 사용	해당없음	C 불안전 함수(strcpy 등) 없음(Python).
48	API 오용	자원 결정 요인으로 보안성이 취약한 알고리즘 사용	양호	보안목적 난수 사용처 없음(토큰 생성 없음). 도입 시 secrets 모듈 권고.
49	API 오용	DNS 변경을 신뢰한 보안 결정	해당없음	도메인(DNS) 기반 인증-접근제어 없음. CORS는 고정 Origin 화이트리스트.

범례 — 양호: 안전 확인 / 조치완료: 취약 → 수정 완료 / 해당없음: 스택-구조상 비해당 / 권고: 운영 전환 시 처리

점검자: _____ 확인(서명): _____ 일자: 2026-06-23